Ripple: audit brief

What was fixed, whether it is battle tested, and whether it is ready for a bug bounty. Branch **fix/ch-trackA** (from main 4a8d820b), C:\ripple. Covers Track A (Chirantan), John's report and Track B (Nandini).

Verdict. Not yet battle tested; ready for a closed, invite-only bug bounty on synthetic data once the steps below are done. Not ready for a public or paid bounty, or for real customer data.

Why: the fixes are **not on any branch** yet (nothing committed or pushed), the deployed site has never been tested, no outside person has attacked it, and all tests were written by the same side that wrote the fixes. No Critical finding is open; the High findings are fixed except the deployment half of A-003/J-005.

1. Results at a glance

Check	Result
Backend unit and API tests	188 OK, 1 skipped (was 158). Same on a clean copy of main plus the patch.
Frontend	tsc 0 errors; vitest 92 pass; production build OK
Browser journeys (Playwright)	Track B 65/65 in Chrome and Edge; Track A 34/34
Postman collection, run with Newman	273 requests, 413 assertions, 0 failed (supervisor password supplied at run time)
Control sweep, every control, 1440 and 390 px	683 observations, 0 FAIL (13 + 12 explained, 6 + 6 destructive ones covered by journeys)
Accessibility (axe-core, WCAG A/AA)	55 violation groups before, 0 after, in 80 scans (3 themes + high contrast)
Hostile-input fuzz over every route	71 routes, over 2,000 bad inputs: no 500, no stack trace, no file path
Page speed, slow phone profile	Layout shift fixed (Khata 0.22 to 0.002, Settings 0.65 to 0.0002). Largest paint 2.5 to 3.3 s vs 2.5 s target

2. What was fixed (38 distinct fixes; each has a regression test or scripted check)

High

ID	Problem	Fix
J-001	Anyone on the shared demo accounts could remove the other demo accounts, invite owners, or reset the shared business	403 SHARED_DEMO_PROTECTED on team invite, remove and reset for the shared demo
J-004	Two pending cheques could each pay the same bill (Rs 2,000 received against a Rs 1,000 bill)	A pending cheque now holds its amount on the bill; clearing re-checks
B-001	A bill number used on two parties was saved, then Today, Book, Engine and Risk all failed for that business, with no screen to undo it	Every forecast event gets a unique id; fix text uses the real bill number
B-002	Dates like 9999-12-31 gave a server 500 or silently poisoned the forecast	One Date type everywhere: 2000 to 2100 only, else 422
A-003 / J-005	Login, demo and AI rate limits bypassed with a forged X-Forwarded-For	Fixed in code (Nth entry from the right, per-account limit). **Open:** real proxy count on the host

Medium

ID	Problem	Fix
J-002	transactions.csv: a party name starting with = became a live formula	Shared formula guard on the party column
J-003	A chunked request body was never size-checked	BodyLimit middleware counts bytes as they arrive, 413 at once
J-006	No screen could clear or bounce a pending cheque	Cleared / Bounced buttons in Book > Ledger
B-003	Stock adjustment could go below zero	NOT_ENOUGH_STOCK
B-004, B-005	Payment and Add-party forms accepted 1e5, 0x10, silent rounding; errors unhandled	Shared parsers, inline errors, double-click guard
B-007	Set-up replaced all records with no confirmation	Confirm dialog (safe default: keep my records)
B-008	WhatsApp links had no country code; landlines linked	91 added to 10-digit mobiles; landlines get no link
B-010 to B-012	Favicon broke on /app pages; no 404, privacy, terms, cookie notice, titles, share tags, robots, sitemap	All added; real 404 status; /.env no longer returns the app
B-013	Colour contrast failed WCAG AA in 45 page/theme combinations	Colour tokens raised in all themes; axe 0 violations
B-021	Scripts sent uncompressed (about 580 KB)	Gzip for text (about 190 KB); smaller Tamil/Hindi fonts
A-001, A-004, A-011	Munim gave the runway answer to almost everything; one render error blanked the app; 19 error codes showed raw	Intent matching; error boundary; friendly messages

Low and Info (summary)

IDs	Fixed
J-007, J-008, J-009, J-010	Stale engine example files (now tested against a fresh run); duplicate bill numbers per party; invite no longer reveals who has an account (5 tries/hour residual); chmod 777 /data removed (container still runs as root for the Railway volume)
B-006, B-009	NaN price in order what-if; transactions.csv BOM so Excel shows Tamil and Hindi names

IDs	Fixed
B-014 to B-020, B-022	ARIA names, keyboard reach, 44 px touch targets, password button, dialog descriptions, strict whole-number money ("100" refused), layout shift, unused API client removed
A-002, A-005, A-008, A-012	Blank Munim question; paise in server text and Rs-minus; 401 mid-session returns to the same page; CA-check wording on statute notes

Still open: A-003 deployment half; A-006 John's branch commits node_modules, dist and a database; A-007 about 1,700 unmounted backend lines; A-009 demo creation limited to 6/min per address; A-010 / B-024 unused routes, 3 are real features with no screen; B-023 Hindi and Tamil translate only navigation, Today and Book.

3. Questions you should be asking

Are we battle tested?
Partly. We ran thousands of automated checks, but only against a local copy, by the team that made the fixes. Nobody outside has attacked it, and it has never run under load, on the real host or on a real phone. Passing tests show the known bugs are gone, not that none remain.

Are we ready for an actual bug bounty?
Closed, invite-only, on a deployed test copy with synthetic data: yes, after the checklist below. Public, paid, or holding real customer data: no.

What must happen first?
(1) Commit, review and merge the patch; it is on no branch yet. (2) Set TRUSTED_PROXY_HOPS (needs the Railway proxy count) and PUBLIC_BASE_URL. (3) Clean or drop John's branch (A-006). (4) Decide the shared demo: its data is still writable by anyone with the documented password. (5) Rerun the Playwright, Newman and fuzz suites against the deployed HTTPS URL. (6) Have /privacy and /terms checked (DPDP Act 2023). (7) Confirm the dependency audit and git-history secret scan, which are Track C scope and were not verified here.

What did we not test?
Firefox, Safari, a real phone, screen readers, the deployed site (HTTPS, Secure cookie, proxies), the Docker build, load or concurrency, migrations and rollback, a live AI model (so prompt-injection against the live Munim or set-up model is untested), microphone dictation, Postman MCP/CLI (Newman used instead).

What will an outside tester probably find?
The documented demo password (by design); demo creation exhausted by one person (A-009); partial Hindi/Tamil; the three API-only features; slow largest paint on slow phones; the 5/hour invite-probe residual; anything in the untested list above.

Is the 188-test number trustworthy?
Yes, with one caveat: a timing test ("risk did not finish") failed once when browsers and Newman shared the CPU. It passes alone in 3 s and in clean runs.

What does the bounty need that is not built?
A reporting channel and rules (no security.txt or contact exists), written scope (our own deployed app only), safe-harbour wording, an agreed way to reset the shared demo between testers, and a rule that no real payments or messages are sent. Remember the bugbounty branch is frozen 12:00 to 2:00 AM.

Is anything unsafe in the repo itself?
No secrets were printed or stored during this work. The container still runs as root on purpose (Railway volume); the real risk is the open items in section 2.

4. Decisions waiting for you

#	Decision	#	Decision
1	Proxy count for TRUSTED_PROXY_HOPS	5	Make the 'ways to fix' terms (2%, 90%, 1.5%, 10 days) settings, or demo-only
2	Delete or integrate the unmounted backend	6	Hindi/Tamil: hire a reviewer, or say 'partly translated' on screen
3	Clean John's branch before merge	7	Legal review of /privacy and /terms
4	Add screens for edit-party, enter-bill, set-promised-date	8	Shared demo writable data; and conflicting Postman files with John's

Files: docs/audit/ROUND2-SUMMARY.md (review order), docs/audit/nandini/ (final-report, bug-ledger, evidence), docs/audit/chirantan/, docs/audit/ripple-all-fixes.patch (119 files; applies cleanly to main). Nothing committed or pushed.